PILOTAGE

Tableau de bord

La posture de sécurité de l'organisation, sur un écran

Le problème

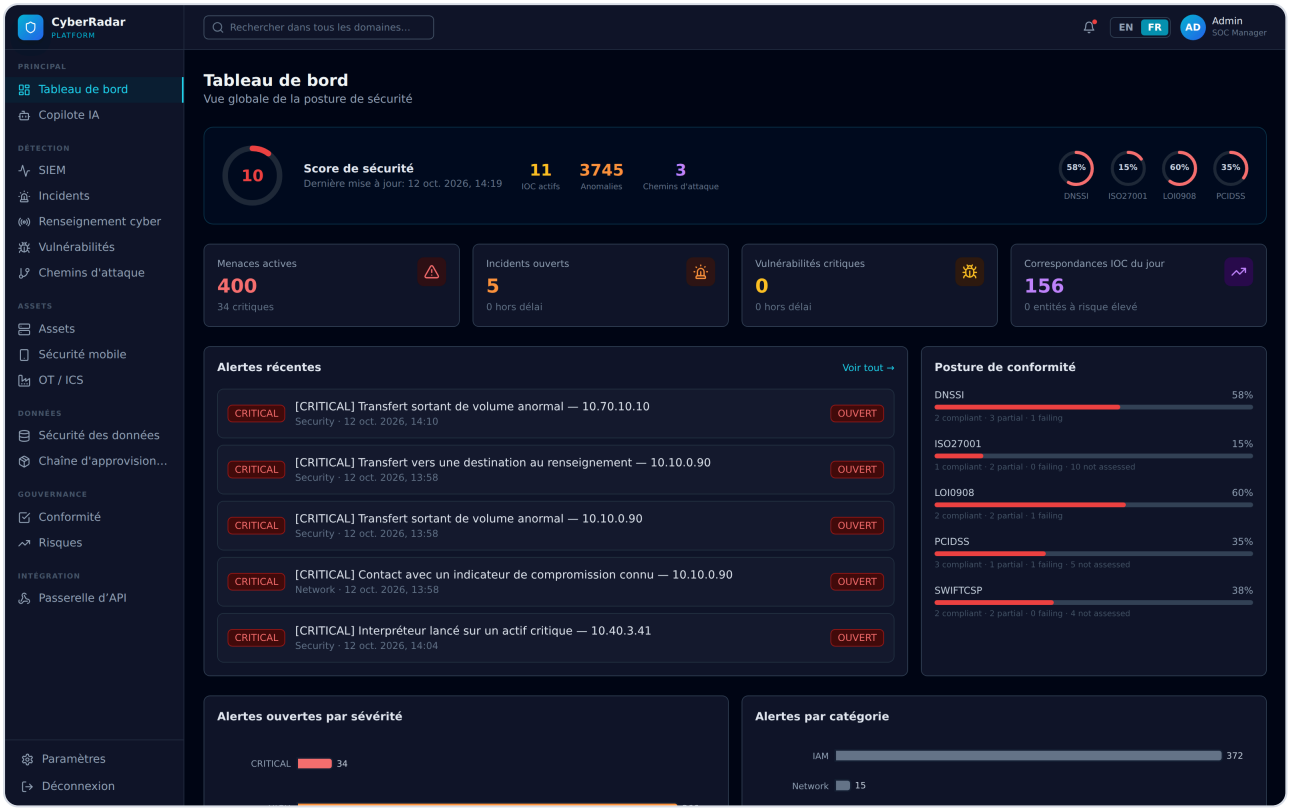
Un comité de direction demande « où en sommes-nous ». La réponse habituelle demande trois jours, cinq exports et un tableur, et elle est périmée le jour où elle arrive.

Ce que fait le module

Une vue unique qui agrège ce que les vingt-cinq domaines savent : les alertes ouvertes, les incidents en cours, les vulnérabilités critiques, les correspondances d'indicateurs du jour, et la posture par référentiel de conformité. Les chiffres ne sont pas recopiés : ils viennent des mêmes données que les écrans d'analyse.

TABLEAU DE BORD

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Score de sécurité

Une note unique, recalculée en continu à partir des alertes ouvertes, des vulnérabilités non traitées et de l'écart de conformité.

Les quatre compteurs

Menaces actives, incidents ouverts, vulnérabilités critiques, correspondances d'indicateurs — chacun avec son dépassement de délai.

Posture de conformité

Un anneau par référentiel. Le détail par contrôle est à un clic.

Alertes récentes

Les dernières levées, avec leur sévérité et leur état. Elles mènent directement au cas.

Comment ça marche

1. Chaque domaine publie ses indicateurs sur le bus d'événements, à son rythme.
2. Le service de tableau de bord les agrège par organisation et les tient à jour.
3. L'écran lit cet agrégat : il n'interroge pas les vingt-cinq domaines à chaque affichage.
4. Un domaine arrêté laisse son dernier chiffre visible, daté — et non une case vide.

Ce que le client y gagne

Une réponse immédiate au comité
La question « où en sommes-nous » a une réponse à l'écran, datée, sans travail de préparation.

Un seul chiffre discutable
Le score agrège ce qui compte. On discute de sa composition, pas de quelle source a raison.

Aucune recopie
Les chiffres du comité et ceux de l'analyste sortent de la même base. Ils ne peuvent pas diverger.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

DÉTECTION

SIEM / XDR

Le moteur de détection, et la bibliothèque qui l'alimente

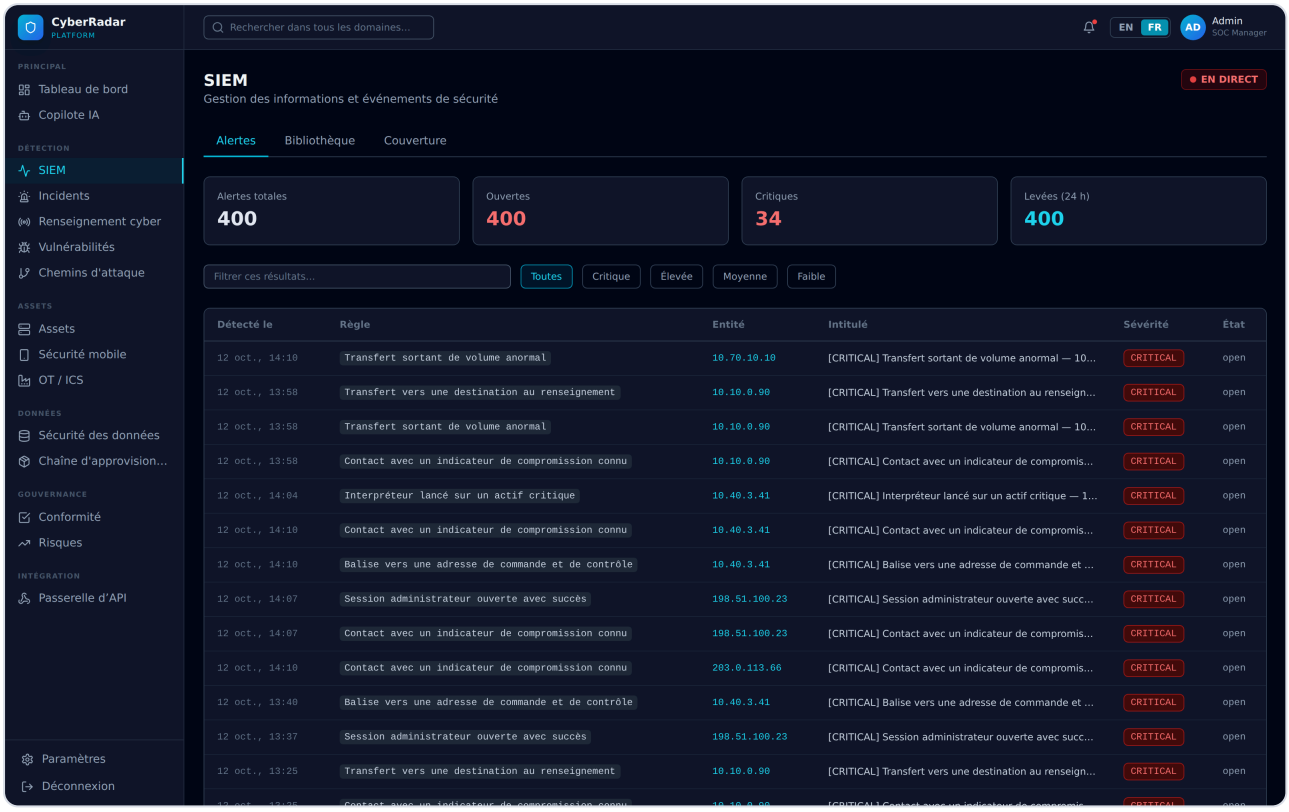
Le problème

Un SIEM se juge sur deux choses : ce qu'il détecte, et ce qu'il ne détecte pas. La seconde est rarement documentée, et c'est pourtant la question d'un auditeur.

Ce que fait le module

Un moteur de corrélation qui consomme les événements normalisés et lève des alertes sur des règles à seuil et à fenêtre. Trois onglets : les alertes, la bibliothèque de détections livrée avec la plateforme, et la couverture ATT&CK qui en découle.

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Les quatre compteurs

Alertes totales, ouvertes, critiques, et levées sur 24 heures.

La colonne Règle

Le nom de la détection qui a déclenché. Ici des règles du catalogue, adoptées et ajustées par le client.

La colonne Entité

L'adresse ou le compte à l'origine. C'est la clé de regroupement du seuil.

Onglet Bibliothèque

Le catalogue livré, ce qui est adopté, ce qui ne l'est pas, et l'écart de chaque règle adoptée par rapport au standard.

Comment ça marche

1. Le moteur consomme le flux d'événements enrichis, en continu.
2. Pour chaque événement, il évalue les règles actives de l'organisation concernée.
3. Une règle à seuil compte les occurrences par entité dans une fenêtre glissante, partagée entre les répliques : deux instances comptent ensemble.
4. Au franchissement, l'alerte est levée, dédupliquée par règle et par entité, puis publiée pour la suite de la chaîne.

Ce que le client y gagne

La couverture est un objet, pas une promesse
Le catalogue est versionné et signé. On sait dire ce qui est couvert, et ce qui ne l'est pas.

L'écart est défendable
Un seuil ajusté garde la trace de son origine. « Pourquoi trois et non cinq » a une réponse écrite.

Les détections se livrent sans montée de version
Une nouvelle famille d'attaque est couverte en heures, sans fenêtre de maintenance.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

VISIBILITÉ

Inventaire d'actifs

Ce que vous possédez, ce que ça vaut, et ce qui en dépend

Le problème

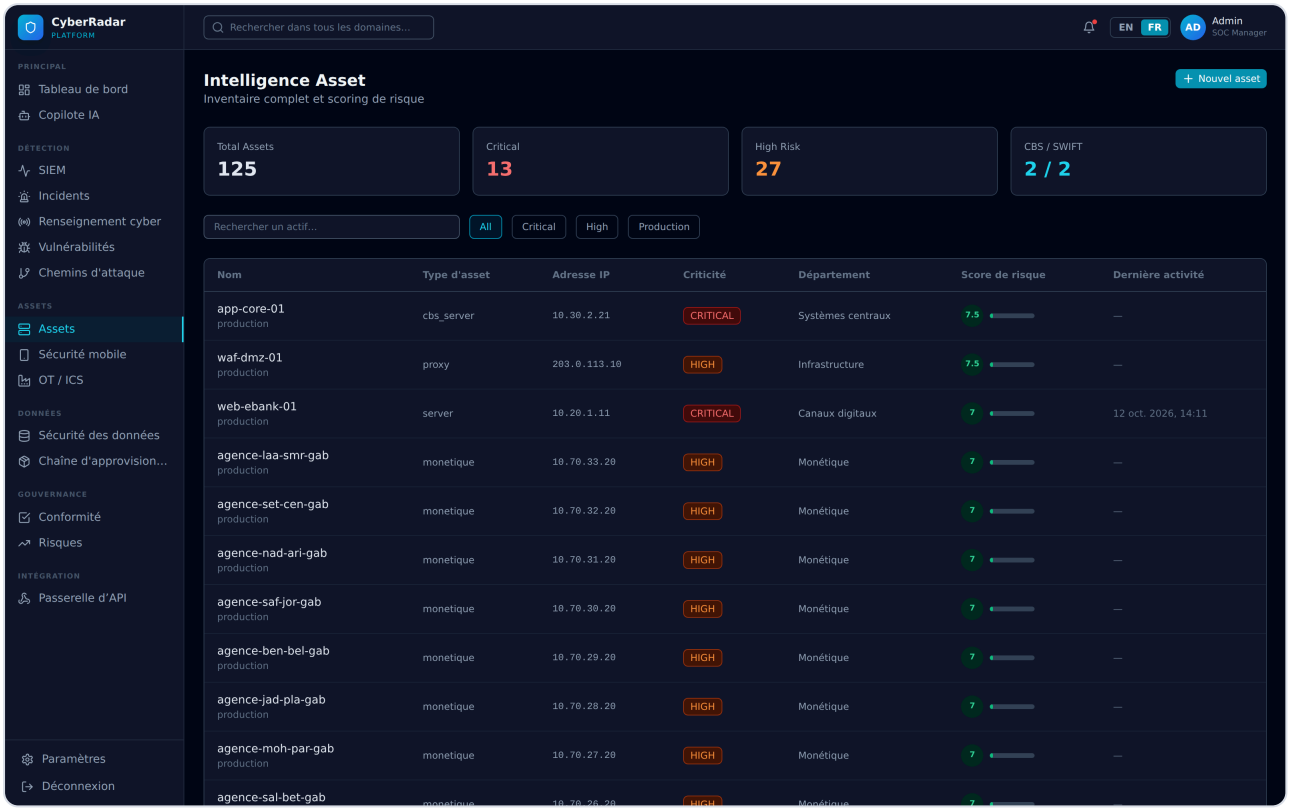
La plupart des inventaires sont des tableurs : justes le jour de leur création. Une alerte sur un serveur dont personne ne sait s'il porte le cœur bancaire est une alerte qu'on ne sait pas prioriser.

Ce que fait le module

Un inventaire où chaque actif porte sa criticité métier, son exposition, son environnement, son service métier, et ses dépendances vers les autres actifs. C'est le référentiel que tous les autres domaines consultent.

INVENTAIRE D'ACTIFS

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Criticité

De 1 à 4, fixée par le métier et non déduite du type de machine.

Portée réglementaire

Les marqueurs cœur bancaire, SWIFT et périmètre carte, qui décident de quels contrôles s'appliquent.

Exposition

Ce qui est joignable depuis l'extérieur, calculé et non déclaré.

Dépendances

Ce que l'actif atteint et ce qui l'atteint — la matière du calcul de chemins d'attaque.

Comment ça marche

1. Les actifs entrent par l'API ou par la découverte, et portent leur propre identifiant d'origine.
2. La criticité et les marqueurs réglementaires sont des décisions métier, saisies une fois.
3. Les dépendances forment un graphe, qui alimente le rayon d'impact et l'analyse de chemins.
4. Le score de risque d'un actif se recalcule à chaque changement de ses vulnérabilités.

Ce que le client y gagne

Une alerte priorisée dès la détection
L'alerte porte la criticité de l'actif. Le tri ne demande pas d'ouvrir un autre outil.

Le rayon d'impact est immédiat
« Si celui-ci tombe, quoi d'autre tombe » se lit, au lieu de se reconstituer.

Un seul inventaire pour tous les domaines
Conformité, vulnérabilités, chemins d'attaque et détection parlent des mêmes objets.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

EXPOSITION

Gestion des vulnérabilités

Non pas la liste des failles, mais l'ordre dans lequel les traiter

Le problème

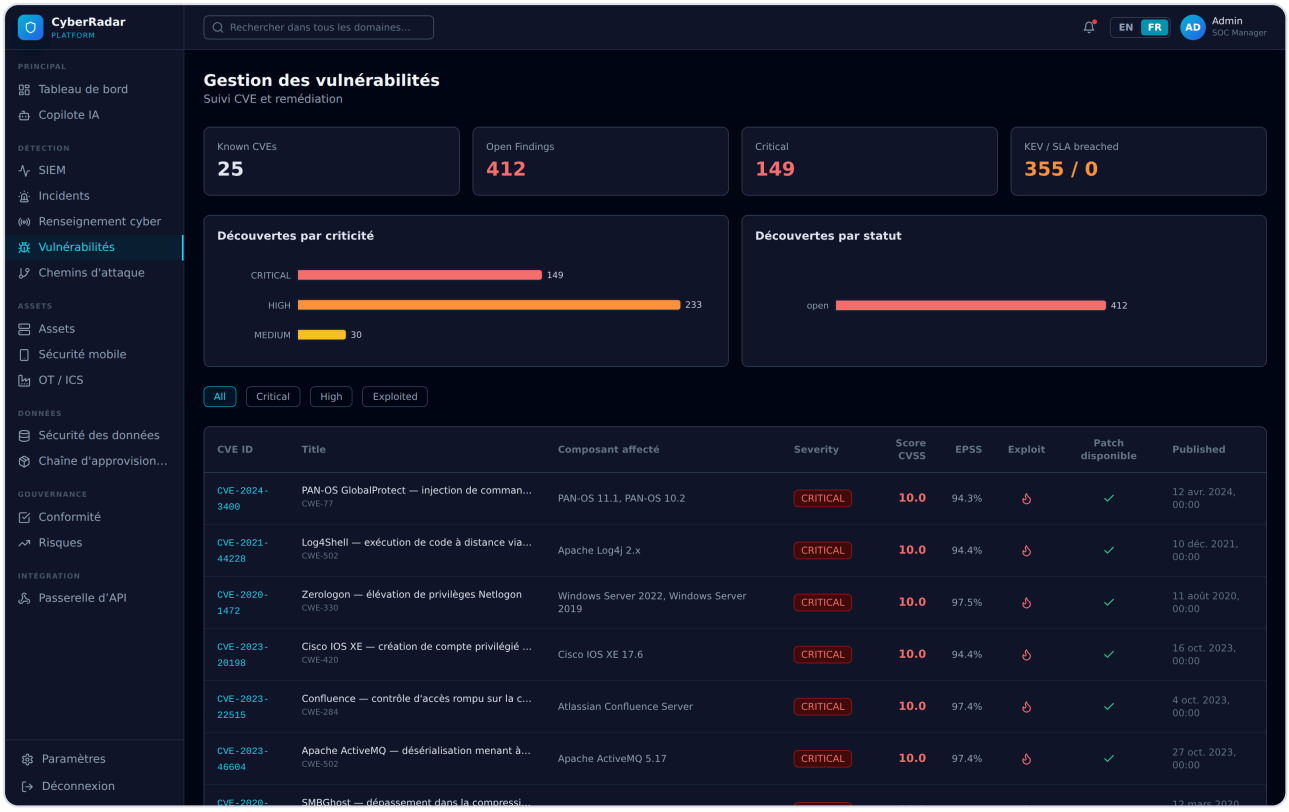
Un scanner rend dix mille lignes. La question n'est pas de les voir, c'est de savoir par laquelle commencer, et de prouver qu'on a respecté ses propres délais.

Ce que fait le module

Les vulnérabilités du catalogue public, les constats par actif, et un classement qui croise la gravité publiée, la probabilité d'exploitation, l'exploitation constatée dans la nature, et la criticité de l'actif touché.

GESTION DES VULNÉRABILITÉS

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Score et probabilité

Le score de base publié, et la probabilité d'exploitation — une valeur datée, pas une vérité permanente.

Exploitée dans la nature

Le marqueur qui change l'ordre de traitement plus que le score lui-même.

Constats par actif

La même vulnérabilité sur quarante machines, c'est quarante constats et une seule fiche.

Délai de remédiation

Le délai que vous avez fixé par criticité, et le dépassement calculé.

Comment ça marche

1. Un constat lie une vulnérabilité à un actif ; les imports de scanner les déposent en lot, par l'API.
2. L'exposition est calculée : une faille distante sur un actif joignable depuis l'extérieur ne pèse pas comme la même sur un poste interne.
3. Les délais de remédiation sont paramétrables par criticité, par organisation.
4. Le dépassement de délai est un état calculé, pas un champ à tenir à jour.

Ce que le client y gagne

Un ordre de traitement défendable
La priorité se justifie par quatre facteurs explicites, pas par le score du scanner.

Vos délais, pas les nôtres
Les délais par criticité sont votre politique. Les changer ne demande pas de livraison.

La preuve du respect des délais
L'échéance et son dépassement sont calculés depuis votre politique et la date de découverte : c'est ce qu'un auditeur demande.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

DÉTECTION

Renseignement sur la menace

Des indicateurs qui influencent la détection, et non un flux à côté

Le problème

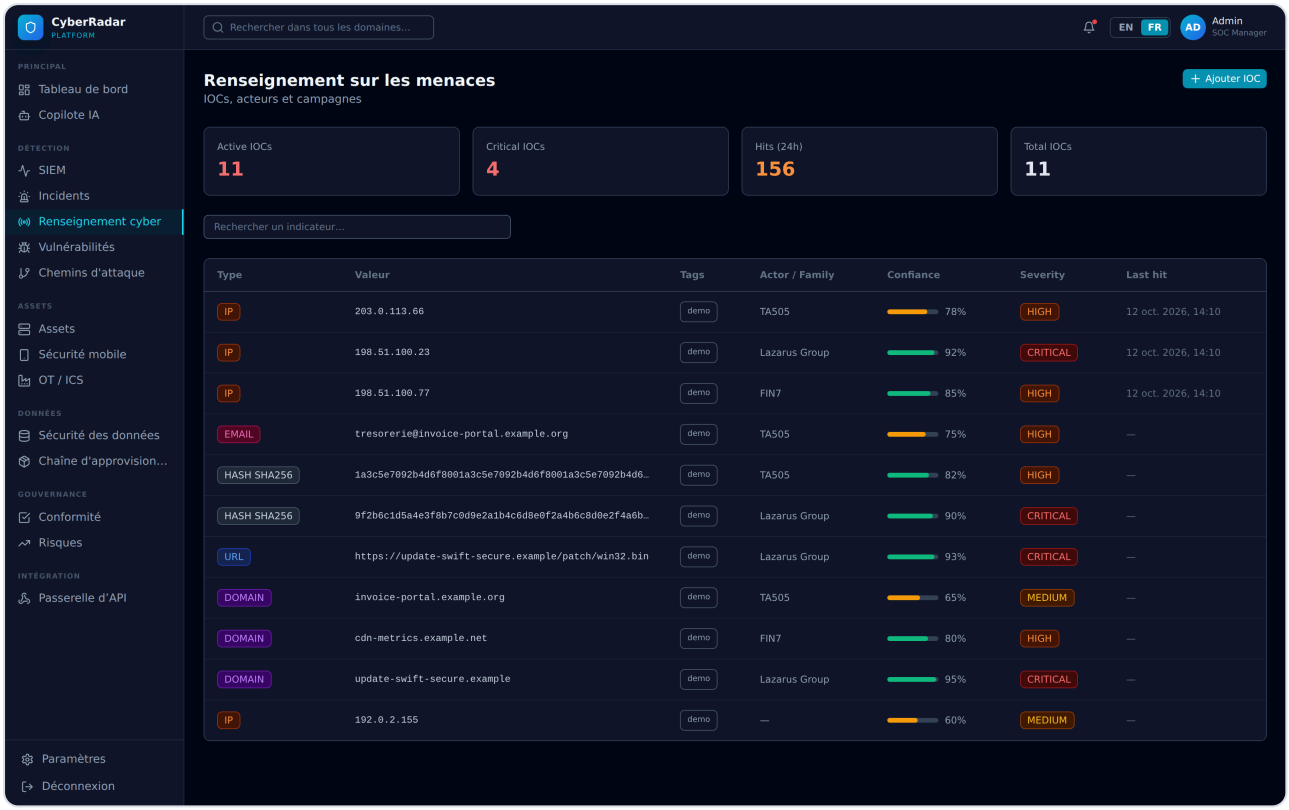
Beaucoup de plateformes consomment des indicateurs puis les affichent dans un écran séparé. Un indicateur reconnu après la décision de détection n'a rien changé.

Ce que fait le module

Un référentiel d'indicateurs — adresses, domaines, empreintes — et d'acteurs de menace, avec l'index de correspondance que le pipeline interroge pendant l'enrichissement, avant que le moteur de règles ne décide.

RENSEIGNEMENT SUR LA MENACE

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Indicateurs actifs

Ce que la plateforme reconnaîtra dans le flux, maintenant.

Acteurs

Les groupes suivis, leurs techniques, et les indicateurs qui leur sont rattachés.

Correspondances

Les événements réels qui ont rencontré un indicateur, avec l'actif concerné.

Comment ça marche

1. Les indicateurs entrent par l'API ou par import, avec leur source et leur date de péremption.
2. Un index en mémoire est tenu à jour et rafraîchi périodiquement par le pipeline d'ingestion.
3. Chaque événement normalisé est confronté à cet index pendant l'enrichissement.
4. Une correspondance élève le score de risque de l'événement avant que les règles ne s'appliquent.

Ce que le client y gagne

Le renseignement change la détection
Une correspondance pèse sur la décision, elle ne la commente pas après coup.

Vos propres indicateurs
Ceux d'un CERT sectoriel, d'un correspondant bancaire ou d'une analyse interne s'ajoutent comme les autres.

Pas de flux imposé
Aucun abonnement n'est obligatoire pour que la plateforme fonctionne.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

DÉTECTION

Chemins d'attaque

Non pas « cet actif est vulnérable », mais « voici comment on atteint le cœur »

Le problème

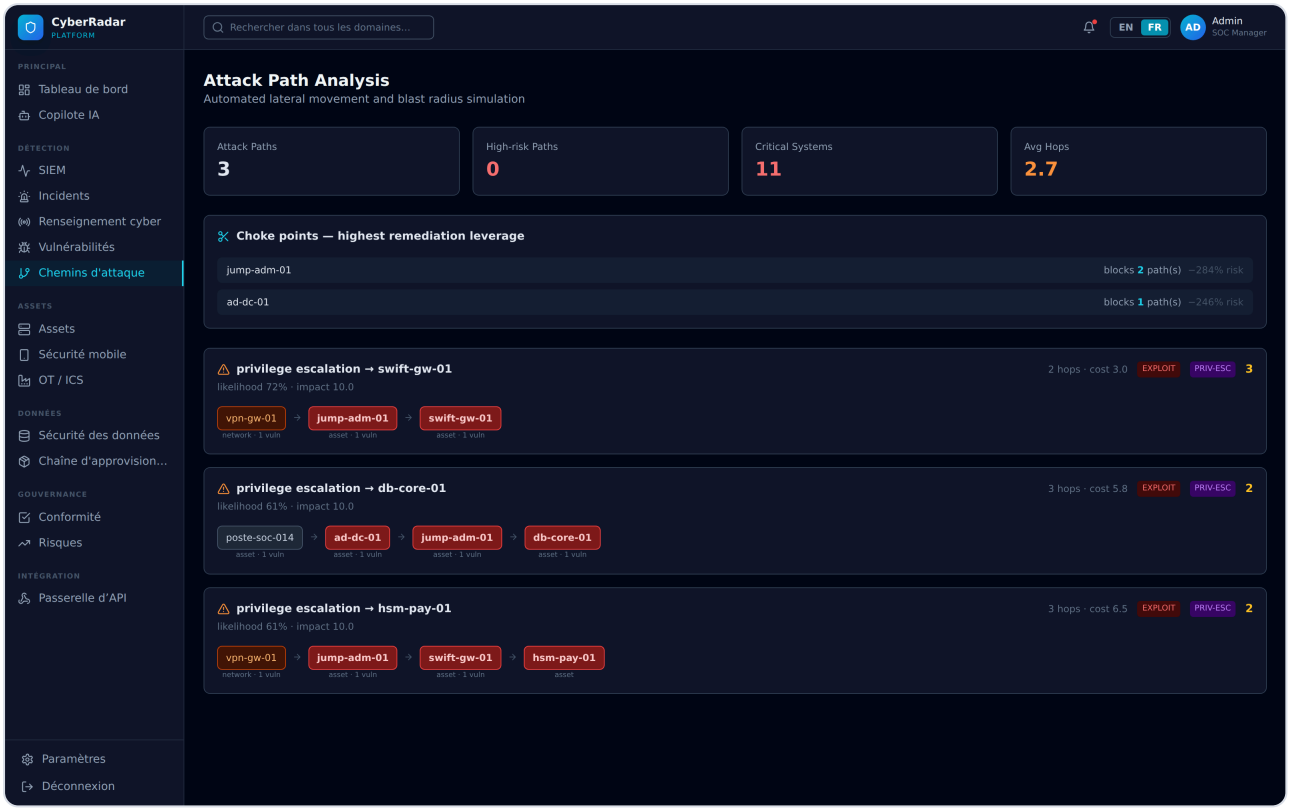
Une vulnérabilité moyenne sur une machine sans importance peut être la première marche vers le système central. Une liste de vulnérabilités ne le montre jamais.

Ce que fait le module

Un graphe des actifs et de leurs dépendances, parcouru pour trouver les chemins qu'un attaquant peut emprunter depuis un point d'entrée jusqu'à une cible de valeur, avec le coût de chaque étape.

CHEMINS D'ATTAQUE

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Scénarios

Un point d'entrée, une cible, et les chemins trouvés entre les deux.

Coût d'un chemin

Ce qu'il en coûte à l'attaquant — plus il est faible, plus le chemin est préoccupant.

Étapes

Chaque saut, la vulnérabilité ou la relation qui le permet, et l'actif traversé.

Comment ça marche

1. Le graphe est construit depuis l'inventaire : actifs, dépendances, comptes, expositions.
2. Chaque arête porte un coût, issu des vulnérabilités présentes et du type de relation.
3. Le parcours cherche les chemins de moindre coût vers les actifs marqués critiques.
4. Les pondérations sont paramétrables : c'est votre jugement du risque, pas le nôtre.

Ce que le client y gagne

Corriger ce qui coupe le chemin
Une correction bien placée ferme plusieurs chemins. L'effort se concentre là où il paie.

Un argument lisible par la direction
« Trois sauts entre internet et le cœur bancaire » se comprend sans être technicien.

Les pondérations sont les vôtres
Ce qui compte comme un saut facile dans votre contexte se règle sans livraison.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

RÉPONSE

Réponse à incident

Du cas ouvert à la clôture, avec la chronologie que l'auditeur demandera

Le problème

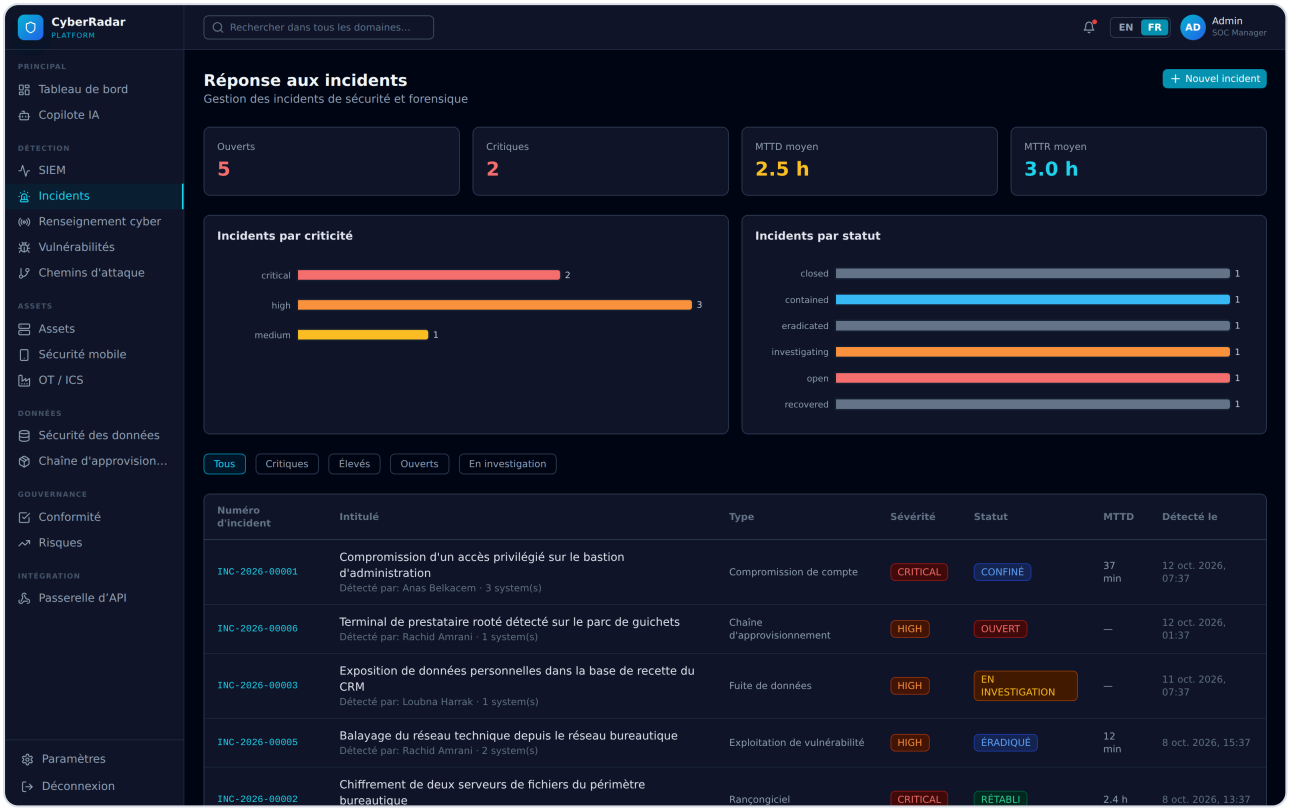
La réponse à incident se gère souvent dans l'outil de ticketing général. Six mois plus tard, reconstituer qui a décidé quoi et quand relève de l'archéologie.

Ce que fait le module

Des incidents avec leur gravité, leurs actifs concernés, leurs tâches, leurs preuves et leur chronologie. Chaque action, humaine ou automatique, s'y inscrit au moment où elle a lieu.

RÉPONSE À INCIDENT

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Gravité et délai

La gravité fixe le délai attendu ; le dépassement est calculé.

Chronologie

L'ordre réel des événements et des décisions, horodaté.

Preuves

Ce qui a été collecté, par qui, et quand.

Tâches

Ce qui reste à faire, et par qui.

Comment ça marche

1. Un incident naît d'une alerte promue, d'un signalement ou d'un playbook.
2. Les actifs concernés viennent de l'inventaire : leur criticité qualifie l'incident.
3. Chaque action écrit dans la chronologie, y compris celles exécutées par un automate.
4. Le délai de détection se déduit de la chronologie — du premier acte attribué à l'attaquant jusqu'à la détection — et le délai de rétablissement de l'événement de reprise, pas de l'heure à laquelle le dossier a été renseigné.
5. La clôture demande une cause et une leçon, qui alimentent le registre des risques.

Ce que le client y gagne

La chronologie existe sans effort
Elle s'écrit pendant l'incident, pas après. C'est la différence entre une trace et un souvenir.

Les délais réglementaires sont suivis
Le délai de notification à l'autorité est un compteur visible, pas une date notée ailleurs.

Les leçons alimentent le risque
Un incident clos nourrit le registre des risques. La boucle se ferme.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

GOUVERNANCE

Conformité réglementaire

Les référentiels du Royaume, reliés à des actifs réels

Le problème

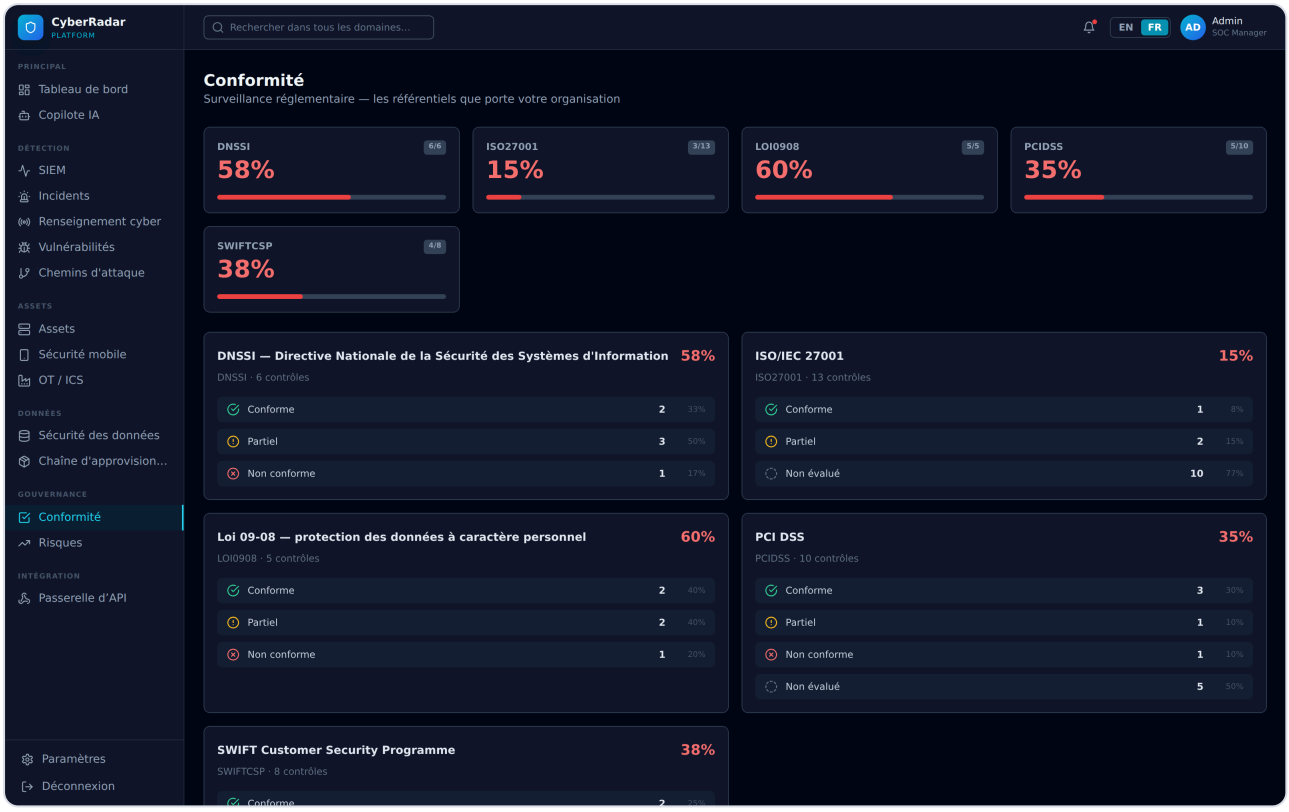
La conformité se démontre souvent par des captures d'écran et des tableurs, reconstitués à chaque audit. Entre deux visites, personne ne sait où l'on en est.

Ce que fait le module

Les référentiels qui obligent un établissement marocain — DNSSI de la DGSSI, loi 09-08 et CNDP, PCI DSS, SWIFT CSP, ISO 27001 — avec, par contrôle, son état, son score, les actifs concernés et la preuve qui l'étaye.

CONFORMITÉ RÉGLEMENTAIRE

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Score par référentiel

La part des contrôles conformes, pondérée. Le détail est en dessous.

Répartition

Conforme, partiel, non conforme, non évalué. « Non évalué » est une information, pas un vide.

Contrôles

Chacun porte son domaine, sa priorité, et la note qui explique son état.

Comment ça marche

1. Un référentiel s'enregistre avec ses contrôles ; la liste n'est pas fermée à quelques cadres occidentaux.
2. Un contrôle se rattache aux actifs qu'il concerne, par marqueur réglementaire ou par sélection.
3. L'évaluation produit un état, un score et une preuve, datés.
4. Les scores par référentiel remontent au tableau de bord sans ressaisie.

Ce que le client y gagne

L'audit se prépare en continu
L'état est à jour en permanence. La visite ne déclenche plus trois semaines de travail.

Les référentiels marocains, pas seulement européens
DNSSI et loi 09-08 sont traités comme PCI DSS ou ISO. Et le vôtre s'ajoute.

Un écart relié à des actifs
« Ce contrôle est partiel » devient « sur ces douze actifs », donc actionnable.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

GOUVERNANCE

Registre des risques

Le risque comme objet suivi, pas comme tableur annuel

Le problème

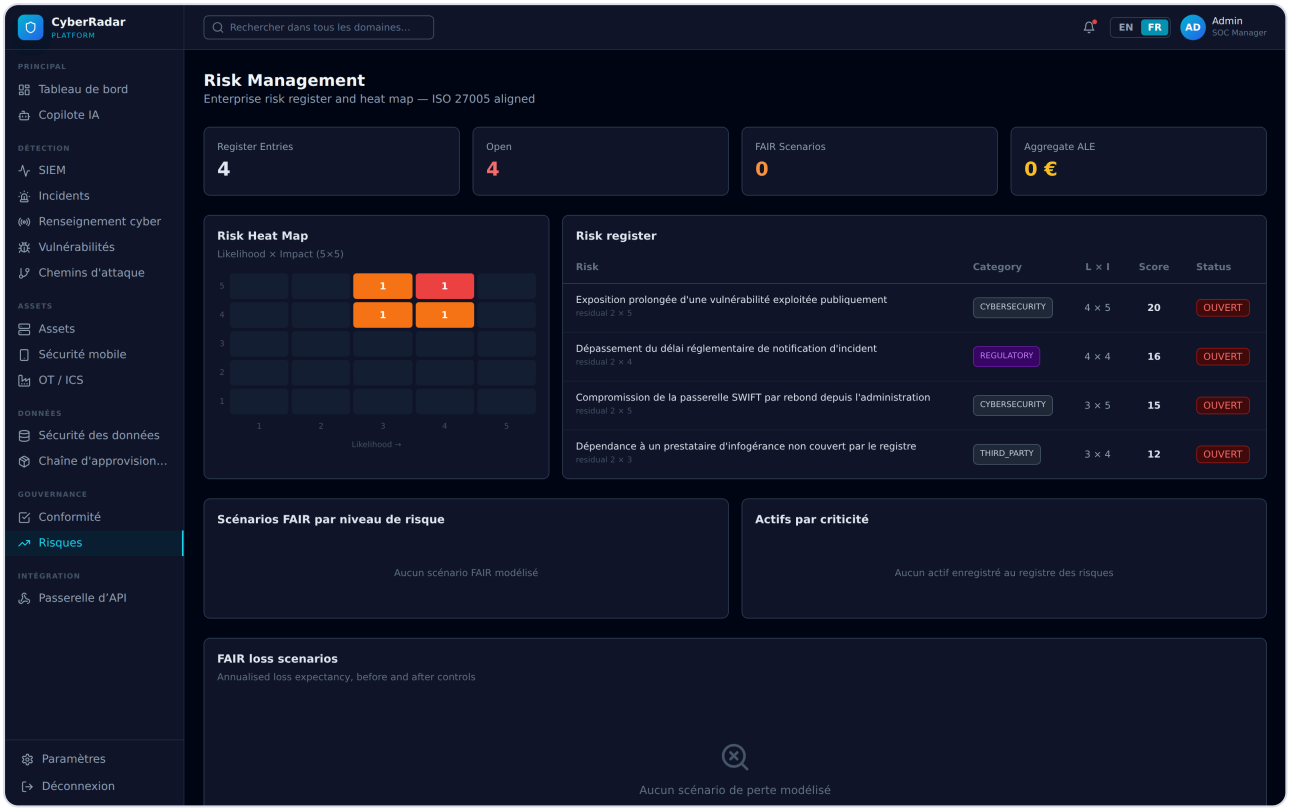
Le registre des risques est souvent un fichier mis à jour une fois par an, déconnecté de ce que la plateforme de sécurité observe tous les jours.

Ce que fait le module

Un registre avec probabilité, impact, score, propriétaire et plan de traitement, alimenté par ce que les autres domaines constatent : incidents clos, écarts de conformité, vulnérabilités persistantes.

REGISTRE DES RISQUES

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Matrice

Probabilité et impact de 1 à 5, et le score qui en découle.

Catégorie

Opérationnel, cyber, réglementaire, tiers, fuite de données.

Propriétaire et état

Qui porte le risque, et où en est son traitement.

Comment ça marche

1. Un risque s'ouvre manuellement ou naît de la clôture d'un incident.
2. Le score croise probabilité et impact, selon l'échelle de l'organisation.
3. Le profil de risque de l'organisation agrège les risques ouverts et leur évolution.
4. Les écarts de conformité et les vulnérabilités persistantes nourrissent la réévaluation.

Ce que le client y gagne

Un registre vivant
Il bouge quand la réalité bouge, pas à date fixe.

Relié à l'opérationnel
Le risque cité au comité est celui que le SOC observe, pas une abstraction parallèle.

L'échelle est la vôtre
Les seuils et les pondérations suivent votre méthode d'appréciation.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

EXPOSITION

Posture des données

Où sont les données sensibles, et qui peut les atteindre

Le problème

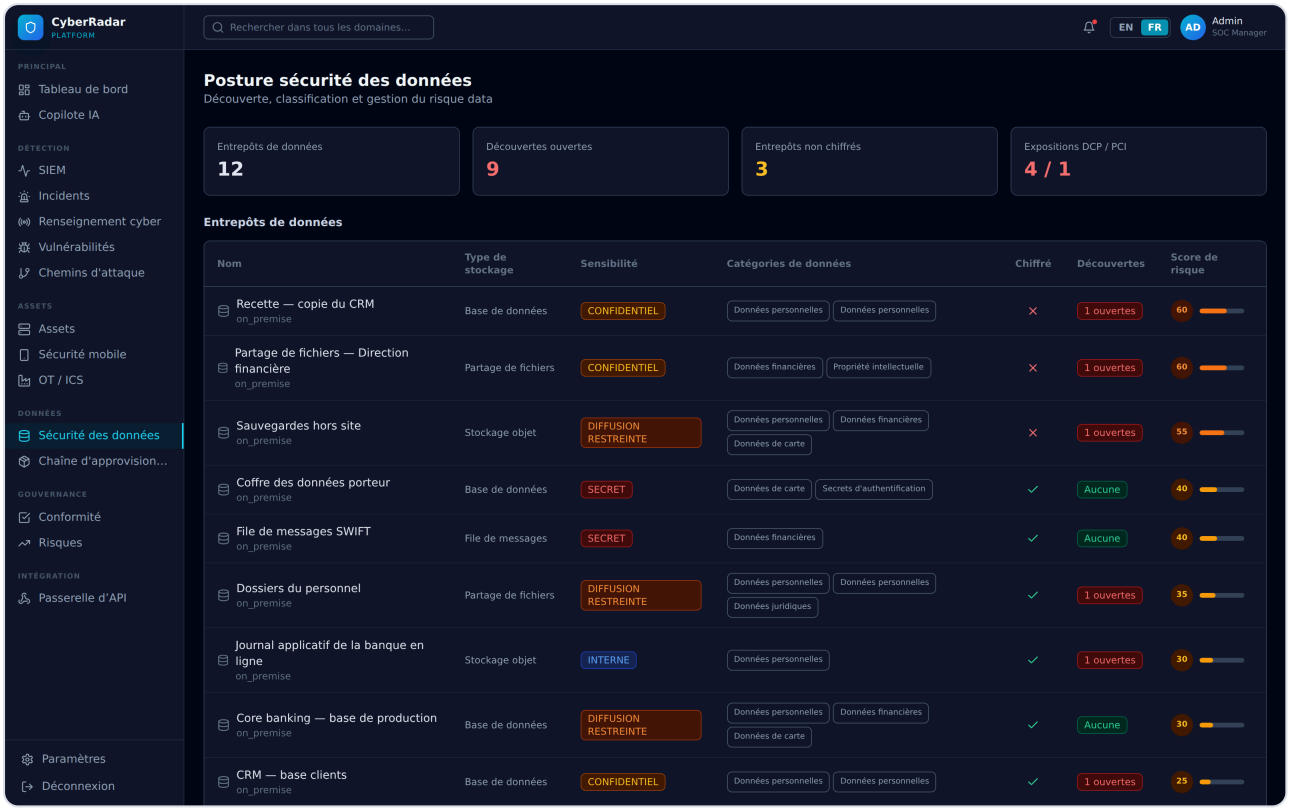
La loi 09-08 impose de savoir quelles données personnelles vous traitez, où elles sont, et qui y accède. Peu d'organisations peuvent répondre sans enquête.

Ce que fait le module

Un inventaire des dépôts de données, leur classification, le type de données qu'ils portent, leur exposition et leurs accès — avec les constats qui en découlent.

POSTURE DES DONNÉES

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Dépôts

Bases, partages, compartiments objet, avec leur classification.

Types de données

Données personnelles, données de carte, secrets — ce qui déclenche une obligation.

Constats

Un dépôt exposé, un accès trop large, un chiffrement absent.

Comment ça marche

1. Les dépôts sont déclarés par l'API, avec leur type, leur hébergement, leur classification et leur posture.
2. La classification peut être déclarée ou déduite d'un échantillonnage.
3. Chaque constat nomme les textes qu'il met en défaut — loi 09-08, PCI DSS — et devient reprenable dans le dossier de conformité.
4. Le score d'un dépôt croise sa sensibilité, son chiffrement, son contrôle d'accès et ses constats ouverts : il bouge dès qu'un constat est ouvert ou refermé.

Ce que le client y gagne

Une réponse à la CNDP
« Quelles données, où, et qui y accède » se lit à l'écran.

Les transferts hors du Royaume se voient
L'hébergement et la région de chaque dépôt sont des colonnes de l'inventaire, pas une découverte faite en audit.

Repris dans le dossier de conformité
Un constat nomme les textes qu'il met en défaut, et se verse tel quel dans l'évaluation du contrôle correspondant.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

EXPOSITION

Chaîne logicielle

Ce que vos fournisseurs et vos dépendances vous font porter

Le problème

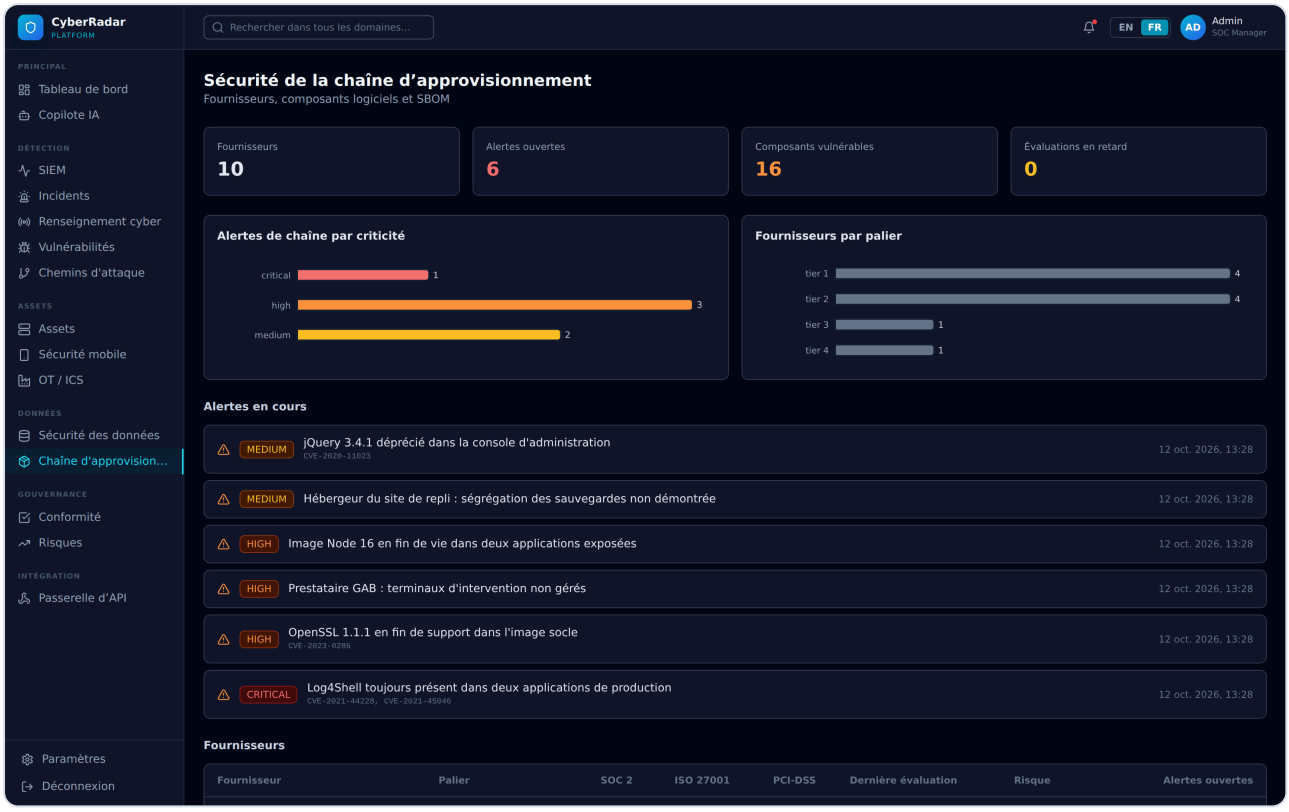
Une part croissante des incidents entre par un fournisseur ou par une bibliothèque. Les deux sont rarement inventoriés avec la même rigueur que les serveurs.

Ce que fait le module

Les fournisseurs, leur évaluation, leurs incidents ; et les composants logiciels des applications, leur version, leurs vulnérabilités et leur fin de support.

CHAÎNE LOGICIELLE

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Fournisseurs

Leur criticité, la date de leur dernière évaluation, et son résultat.

Composants

Les bibliothèques, leur version, et ce qu'on y connaît de vulnérable.

Alertes

Un composant en fin de support, un fournisseur dont l'évaluation est périmée.

Comment ça marche

1. Une nomenclature logicielle importée crée ou met à jour les composants d'une application.
2. Le score de risque d'un composant croise ses vulnérabilités critiques, sa fin de support et son abandon.
3. Une évaluation close avec sa note fixe la date et le score de risque du fournisseur : la liste se classe sur ce que l'évaluation a constaté, pas sur une saisie.
4. Chaque composant déclare les applications qui l'embarquent : le périmètre d'un avis publié se lit sans enquête.

Ce que le client y gagne

Le risque fournisseur devient suivi
Le registre des prestataires critiques exigé par la DNSSI existe, à jour.

Une faille de bibliothèque trouve ses applications
« Qui embarque cette version » a une réponse immédiate, tirée de la nomenclature et non d'un courriel.

La fin de support est anticipée
Elle se voit avant d'être un constat d'audit.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

EXPOSITION

Systèmes industriels

Les équipements qu'on ne redémarre pas, et les zones qui les protègent

Le problème

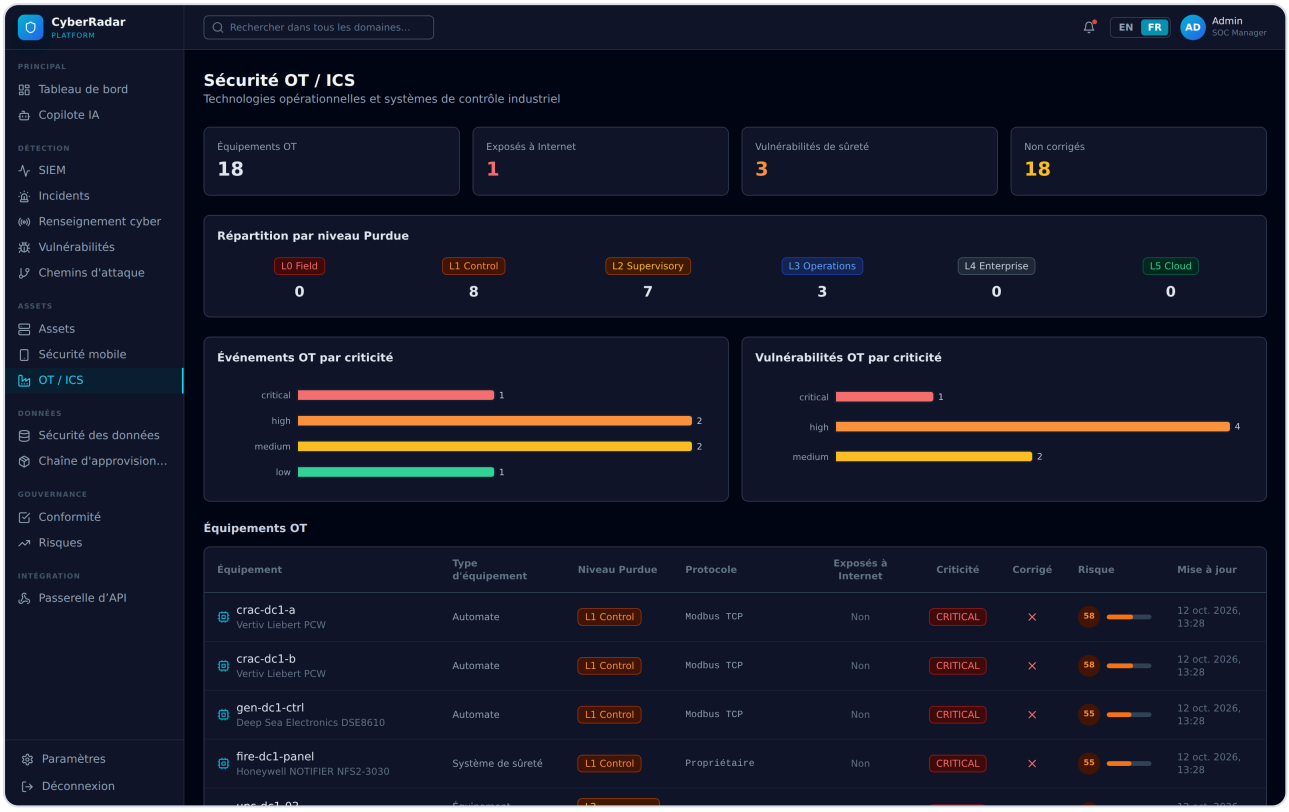
Un automate ne se patche pas comme un serveur, et un scanner classique peut l'arrêter. Les outils informatiques traditionnels y sont inadaptés, voire dangereux.

Ce que fait le module

Un inventaire des équipements industriels par zone, leurs protocoles, leurs vulnérabilités, et les politiques d'isolement entre zones.

SYSTÈMES INDUSTRIELS

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Zones

Le découpage en niveaux, et ce qui a le droit de traverser.

Équipements

Automates, supervision, passerelles, avec leur criticité de procédé.

Politiques

L'isolement attendu entre zones, et les écarts constatés.

Comment ça marche

1. Les équipements sont déclarés par l'API ou repris de l'outil de supervision : la plateforme n'émet rien sur le réseau industriel.
2. Les avis — CVE et ICS-CERT — sont rattachés aux équipements sans aucun balayage : un automate ne se sonde pas.
3. Les politiques de zone décrivent ce qui est autorisé ; l'écart est ce qui se voit en premier.
4. Le score de risque d'un équipement tient compte de la criticité du procédé, pas seulement de la faille.

Ce que le client y gagne

Aucune sonde intrusive
L'inventaire se constitue sans risquer d'arrêter une chaîne.

La segmentation s'écrit avant de se discuter
Les zones, leurs niveaux et les flux attendus sont déclarés : l'écart relevé devient un constat daté plutôt qu'un souvenir d'atelier.

Un vocabulaire industriel
Zones, procédés et criticité de production, pas seulement adresses et ports.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

EXPOSITION

Flotte mobile

Les terminaux qui portent vos applications bancaires

Le problème

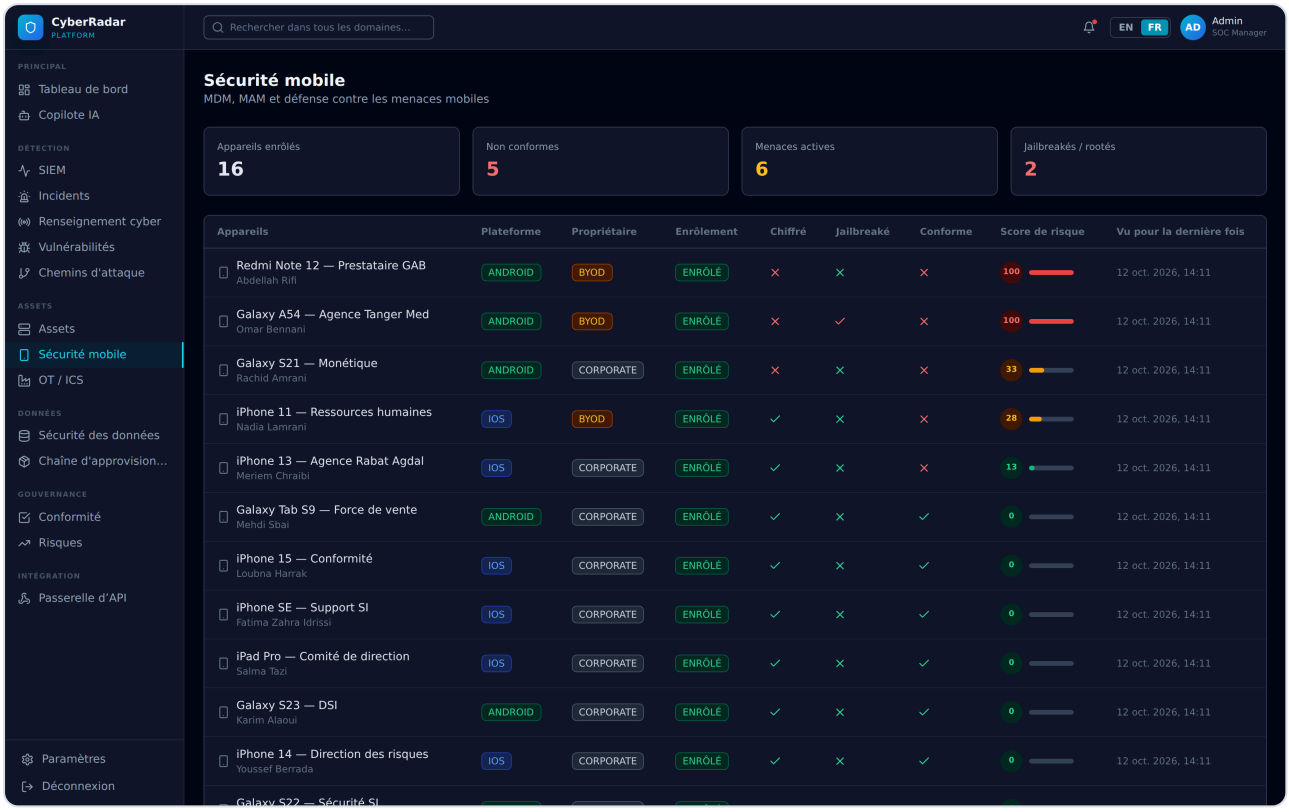
Un terminal compromis ou débridé qui porte l'application bancaire du client est une exposition directe, et elle est rarement dans le même écran que le reste.

Ce que fait le module

Les terminaux enrôlés, leur système, leur conformité à la politique, les applications installées, et les actions à distance disponibles.

FLOTTE MOBILE

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Terminaux

Système, version, état d'enrôlement, dernière communication.

Conformité

Débridage, version non supportée, chiffrement absent.

Actions

Verrouillage et effacement à distance, tracés comme toute autre action.

Comment ça marche

1. L'outil de gestion de flotte dépose l'état de chaque terminal par l'API : chiffrement, verrouillage, déverrouillage du système, écarts constatés.
2. La politique définit ce qui rend un terminal non conforme.
3. Une action à distance passe par la même autorisation et la même trace que le reste de la plateforme.
4. Un terminal non conforme devient un constat, relié à son propriétaire.

Ce que le client y gagne

Les terminaux dans la même vue
Ils cessent d'être un angle mort géré par un autre outil et une autre équipe.

Les actions à distance sont tracées
Un effacement est nominatif et horodaté — ce qui est aussi une protection pour l'exploitant.

Le cloisonnement vaut aussi ici
Un client ne peut pas agir sur le terminal d'un autre, et c'est vérifié à chaque écriture.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

RÉPONSE

Passerelle d'API

Par où les autres systèmes entrent, et par où la plateforme sort

Le problème

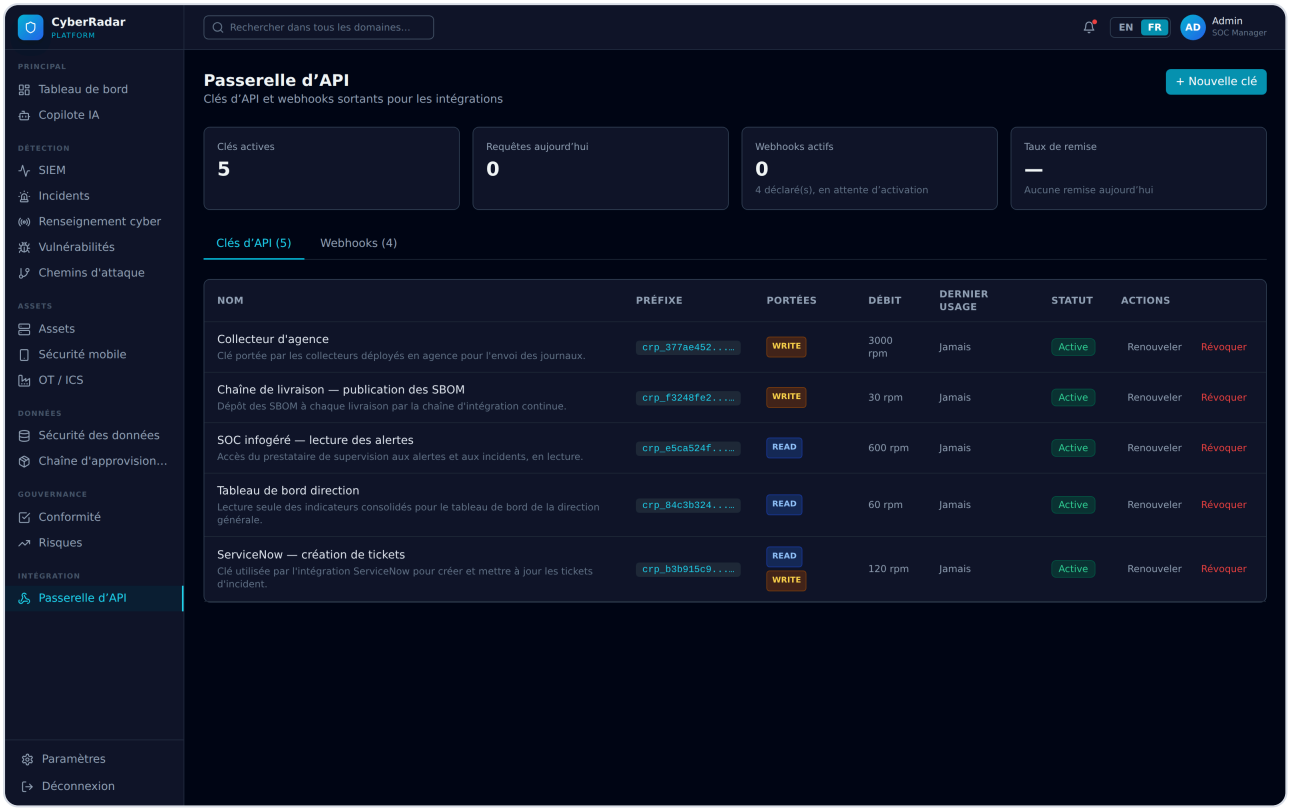
Une plateforme de sécurité qui ne se branche pas devient une vingt-et-unième console. Et un accès machine ouvert « le temps du projet », sans portée ni limite ni date, est un accès qui restera ouvert.

Ce que fait le module

Les clés d'API par lesquelles un système tiers lit la plateforme — chacune avec ses portées, sa limite de débit et son dernier usage — et les webhooks par lesquels la plateforme pousse ses événements vers l'outillage de l'organisation.

PASSERELLE D'API

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Clés

À qui, pour quoi faire, à quel débit, et quand elles ont servi pour la dernière fois.

Portées

Lecture, écriture, administration : ce que la clé a le droit de faire, et rien de plus.

Webhooks

Les événements poussés, vers quelle adresse, et l'état des dernières remises.

Remises

Ce qui est parti, ce qui a échoué, et depuis combien de temps.

Comment ça marche

1. Une clé est affichée une seule fois, à sa création : la plateforme n'en conserve qu'une empreinte SHA-256.
2. Chaque clé porte ses portées, ses limites de débit et sa date d'expiration — le contrat déclaré de l'accès machine, et ce que le registre permet de revoir.
3. Renouveler une clé la remplace sans supprimer l'intégration ; la révoquer l'invalide immédiatement.
4. Un webhook signe son envoi avec un secret partagé (en-tête X-CRP-Signature), pour que le récepteur sache d'où il vient.
5. Une remise en échec est réessayée trois fois, puis consignée avec son code de retour : l'intégration dit elle-même quand elle est rompue.
6. Les appels entrants de la plateforme sont aujourd'hui authentifiés par le fournisseur d'identité de l'organisation. L'authentification par clé, avec application des portées et du débit, est la prochaine étape de ce module.

Ce que le client y gagne

Les événements vont vers vos outils, pas l'inverse
Un incident critique ouvre un ticket chez vous, signé et réessayé. La plateforme s'insère dans l'exploitation existante au lieu d'en demander une nouvelle.

Une intégration rompue se voit
Les remises en échec sont comptées et datées par destinataire. Un connecteur mort cesse d'être une découverte faite le jour où l'on en a besoin.

L'accès machine est déclaré avant d'être ouvert
Qui aura accès, pour quoi faire, à quel débit, jusqu'à quand : le registre existe et se revoit, au lieu d'un compte technique créé « le temps du projet ».

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

PILOTAGE

Assistant d'investigation

Une question en français, une réponse tirée de vos propres données

Le problème

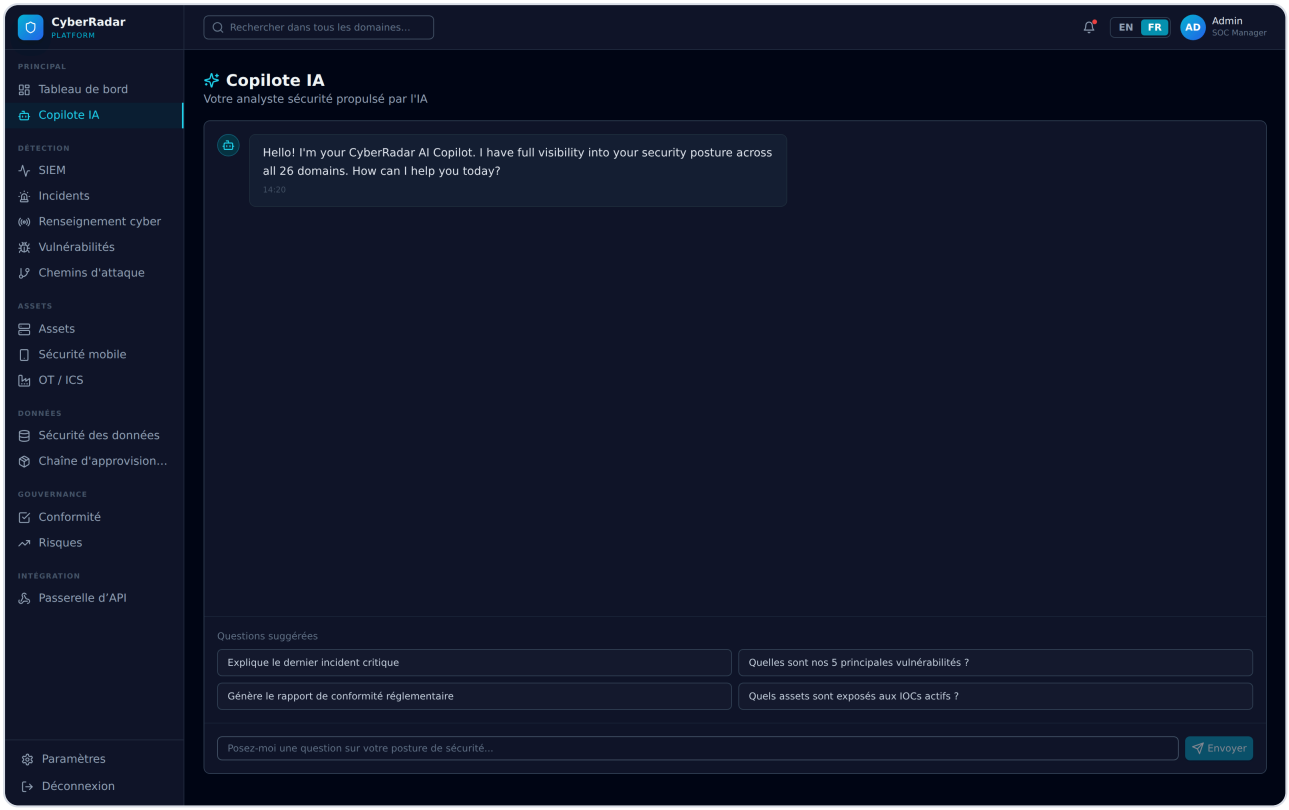
Les données existent, mais il faut connaître six écrans et un langage de requête pour les croiser. L'analyste expérimenté sait ; les autres attendent.

Ce que fait le module

Un assistant qui interroge la plateforme à votre place : il appelle ses propres API, croise les domaines, et répond en citant ce qu'il a lu.

ASSISTANT D'INVESTIGATION

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

La question

En langage naturel — « quels actifs exposés portent une vulnérabilité exploitée ».

Le raisonnement

Les appels qu'il a faits pour répondre, visibles.

La réponse

Avec les objets concernés, cliquables.

Comment ça marche

1. L'assistant dispose d'outils : interroger les actifs, les alertes, les vulnérabilités, la conformité.
2. Il agit avec le jeton de la personne connectée, donc avec ses permissions — et pas davantage.
3. Les documents internes sont indexés pour que les réponses citent vos procédures.
4. Il est optionnel : il s'appuie sur un modèle externe, et la plateforme fonctionne sans lui.

Ce que le client y gagne

Le niveau 1 gagne en autonomie
Une question qui demandait un expert se pose directement.

Les permissions sont respectées
L'assistant ne voit que ce que la personne a le droit de voir.

Désactivable
C'est le seul composant qui appelle l'extérieur. Il se coupe sans perdre le reste.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.

SOCLE

Paramétrage

Ce qui relève de votre politique ne doit pas être dans notre code

Le problème

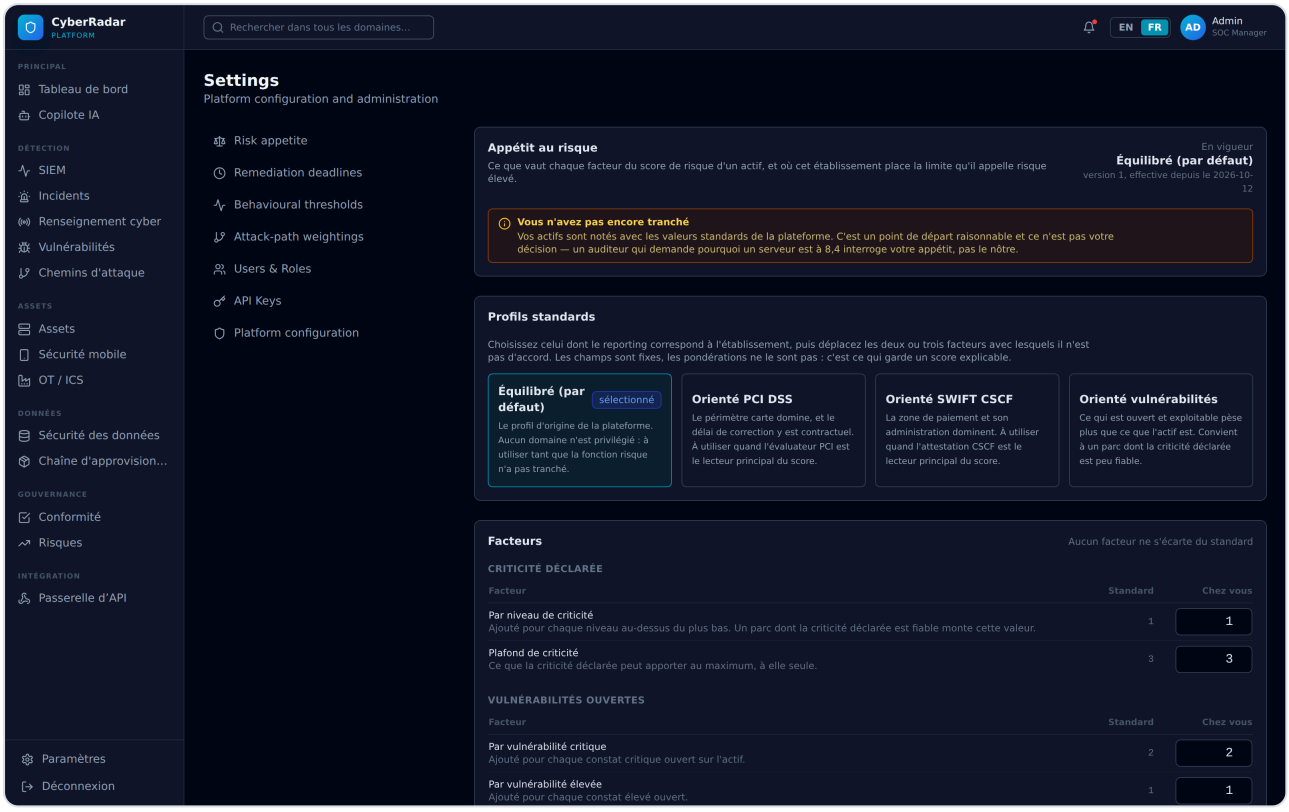
Changer un seuil de détection demande souvent un ticket chez l'éditeur et une montée de version. Une politique de sécurité qui dépend d'une livraison n'est pas une politique.

Ce que fait le module

Quatre familles de décisions, paramétrables par organisation : les seuils comportementaux, les délais de remédiation par criticité, les pondérations des chemins d'attaque, et l'adoption des détections.

PARAMÉTRAGE

L'écran, tel qu'il est



Capture réelle de la plateforme — Banque Al Massira, jeu de démonstration (125 actifs, 24 agences). Aucune retouche.

Ce que l'écran montre

Seuils comportementaux

À partir de combien d'écarts un comportement devient suspect.

Délais de remédiation

Le nombre de jours accordé par criticité de vulnérabilité.

Pondérations

Ce qui compte comme un saut facile dans le calcul de chemins.

PARAMÉTRAGE

Comment ça marche

1. Chaque politique est une donnée de l'organisation, pas une constante du code.
2. Une modification prend effet sans redémarrage ni livraison.
3. Les valeurs par défaut sont celles d'une banque de détail ; elles se discutent.
4. Chaque politique est versionnée et porte qui l'a posée : une valeur en vigueur se rattache à une décision datée.

Ce que le client y gagne

Votre politique vous appartient
Les quatre décisions se prennent par votre équipe, sans nous.

Aucune fenêtre de maintenance
Un seuil change en séance, pendant un comité de sécurité.

Chaque organisation la sienne
Deux filiales du même groupe peuvent avoir des politiques différentes.

Souveraineté. Ce module fonctionne entièrement sur votre infrastructure. Aucun flux sortant n'est nécessaire à son fonctionnement.